Seguridad AWS

José A. Santos García

Task 1. Responsabilidad compartida

Seguridad DE la nube y seguridad EN la nube

Seguridad DE la nube: es la parte que le corresponde a AWS. Consiste en proteger la infraestructura sobre la que funcionan todos los servicios: los edificios y centros de datos, los servidores y equipos físicos, la red global y el software de virtualización que hay por debajo. El cliente no puede tocar nada de esto; simplemente confía en que AWS lo mantiene seguro.

Seguridad EN la nube: es la parte que le corresponde al cliente. Se refiere a todo lo que la empresa crea, configura o guarda dentro de AWS: sus datos, los usuarios y permisos, las reglas de firewall, el sistema operativo de sus máquinas virtuales y las aplicaciones que instala. Cuánto debe proteger el cliente depende del servicio; en EC2, por ejemplo, tiene más responsabilidad que en un servicio totalmente gestionado.

En resumen: AWS protege la nube en sí misma y el cliente protege lo que pone dentro de ella.

Situaciones concretas

a) Mantenimiento de los servidores físicos de AWS: AWS. Es hardware que pertenece a AWS y que está en sus centros de datos, así que forma parte de la seguridad DE la nube.

b) Configuración de las reglas de un Security Group de EC2: la empresa. El Security Group es el firewall de cada instancia y es la empresa quien decide qué puertos y qué direcciones IP pueden acceder. AWS ofrece la herramienta, pero la configuración es responsabilidad del cliente (seguridad EN la nube).

c) Actualización del SO de una instancia EC2: la empresa. EC2 es un servicio de infraestructura: AWS entrega la máquina virtual, pero el sistema operativo instalado en ella y sus parches de seguridad los gestiona el cliente (seguridad EN la nube).

d) Protección de las contraseñas de usuarios IAM: la empresa. AWS proporciona el servicio IAM y funciones como las políticas de contraseñas o la autenticación multifactor, pero es la empresa quien debe usar contraseñas robustas, activar MFA, rotar credenciales y no compartirlas (seguridad EN la nube).

e) Refrigeración de los centros de datos: AWS. Es una medida de seguridad física y de continuidad de la infraestructura, por lo que corresponde a AWS (seguridad DE la nube).

Task 2. IAM

Conceptos básicos

Usuario IAM: es la identidad que representa a una persona concreta (o a una aplicación) dentro de una cuenta de AWS. Tiene sus propias credenciales (contraseña para la consola, claves de acceso para la línea de comandos o la API) y sirve para saber quién hace cada acción y limitar lo que puede hacer.

Grupo IAM: es un conjunto de usuarios IAM. Sirve para asignar permisos de forma conjunta: se adjunta la política al grupo y todos sus miembros la heredan. Así es más fácil de administrar que dar permisos usuario por usuario, y si alguien cambia de función basta con moverlo de grupo.

Rol IAM: es una identidad con permisos que no pertenece a una persona concreta ni tiene contraseña propia; en su lugar, quien lo necesita lo asume de forma temporal. Se usa, por ejemplo, para que una instancia EC2 acceda a S3 sin guardar claves dentro de la máquina, para dar acceso a otra cuenta de AWS o para servicios como Lambda. Las credenciales que obtiene son temporales, lo que lo hace más seguro.

Política IAM: es un documento (en formato JSON) que define qué se permite o se deniega: qué acciones, sobre qué recursos y, opcionalmente, bajo qué condiciones. Por sí sola no hace nada; hay que asociarla a un usuario, grupo o rol. Es la pieza que realmente concede o limita los permisos.

Caso de los tres empleados

a) ¿Deberían tener los tres los mismos permisos? No. Cada empleado tiene una función distinta: Ana administra todo, Luis solo necesita consultar instancias EC2 y Marta solo necesita consultar información de S3. Si los tres tuvieran los mismos permisos, Luis y Marta podrían modificar o borrar recursos que no necesitan tocar, y un error o una cuenta comprometida tendría un impacto mucho mayor. Los permisos deben ajustarse a lo que cada persona necesita para su trabajo.

b) ¿Qué permisos se le debería conceder a Luis? Únicamente permisos de lectura sobre EC2: poder ver las instancias y su información (acciones de tipo ec2:Describe*). Esto se cubre con una política de solo lectura de EC2, como AmazonEC2ReadOnlyAccess. No debería poder iniciar, detener, crear, modificar ni terminar instancias. Lo ideal es meterlo en un grupo de soporte de EC2 y darle los permisos a través del grupo.

c) ¿Qué principio de seguridad se le debe aplicar a cada empleado? El principio de mínimo privilegio: cada persona recibe solo los permisos imprescindibles para su tarea y nada más. En la práctica:

Ana: necesita permisos de administración porque su función es gestionar todos los recursos, pero aun así conviene limitarlos a lo necesario, activar MFA y no usar la cuenta raíz para el trabajo diario.

Luis: solo lectura de EC2, sin capacidad de modificar nada.

Marta: solo lectura de S3 (listar buckets y leer objetos, por ejemplo con AmazonS3ReadOnlyAccess), sin el permiso s3:DeleteObject, por lo que no puede eliminar objetos.

Task 3. Política IAM de la práctica 2.2

He elegido la política EC2-Admin-Policy, asignada al user-3 en la práctica 2.2. Es la que le permitió detener la instancia LabHost, mientras que user-2 recibió un error de acceso denegado al intentarlo.

Archivo JSON

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Action": [
        "ec2:Describe*",
        "ec2:StartInstances",
        "ec2:StopInstances"
      ],
      "Resource": [
        "*"
      ],
      "Effect": "Allow"
    }
  ]
}
```

Significado de cada elemento

Llaves { } exteriores: delimitan el documento de la política completo. Dentro van sus elementos principales.

"Version": "2012-10-17": indica la versión del lenguaje de políticas que se usa. 2012-10-17 es la versión vigente y la que se debe poner siempre; no es la fecha de creación de la política.

"Statement": es la lista de sentencias de la política, es decir, de las reglas concretas. Va entre corchetes porque puede contener varias; en este caso solo hay una.

Llaves { } interiores: delimitan una sentencia individual, que agrupa Action, Resource y Effect.

"Effect": "Allow": define si la sentencia permite o deniega las acciones. Allow las permite; la otra opción posible es Deny. Aquí se conceden los permisos listados.

"Action": es la lista de acciones de la API de AWS que afecta la sentencia, escritas como servicio:acción. En esta política son tres:

"ec2:Describe*": el asterisco es un comodín, así que incluye todas las acciones que empiezan por Describe (ver instancias, grupos de seguridad, volúmenes, etc.). Es decir, permite consultar.

"ec2:StartInstances": permite iniciar instancias EC2 que estén detenidas.

"ec2:StopInstances": permite detener instancias EC2 en ejecución.

"Resource": ["*"]: indica sobre qué recursos se aplican las acciones. El asterisco significa todos los recursos, o sea, todas las instancias de la cuenta. Podría restringirse a una instancia concreta usando su ARN.

En conjunto, la política permite consultar todas las instancias EC2 y iniciarlas o detenerlas, pero no crearlas, modificarlas ni terminarlas, ni toca otros servicios como S3. Por eso encaja con el resultado de la práctica: user-3 pudo detener LabHost, y como cualquier acción no incluida queda denegada por defecto, no tiene más poder del necesario.